

SIMATS ENGINEERING ASSESSMENT TOOL 2

COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY
COURSE CODE: CSA51

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)

Scenario-Based : 20%

Total Marks: 50

Annexure A

Code of Conduct:

I Kanmani L/192511414 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:



Annexure A

1. Secure Password Storage in Web Applications

A web application stores user passwords and needs to protect them against database breaches.

- A. Explain why storing plaintext passwords is insecure.
 - B. Suggest a secure method for storing passwords and justify your choice.
-

2. Digital Signature for Document Authentication

A company wants to ensure that official documents sent electronically are authentic and unaltered.

- A. Explain how digital signatures can be used in this scenario.
 - B. Justify how this method ensures both integrity and non-repudiation.
-

3. Preventing Replay Attacks in Online Transactions

An online payment system is vulnerable to replay attacks where attackers resend previously captured transactions.

- A. Explain how replay attacks occur.
 - B. Suggest a cryptographic technique to prevent such attacks and justify your answer.
-

4. Secure Communication over Public Wi-Fi

A user accesses sensitive information using a public Wi-Fi network without encryption.

- A. Identify the risks involved in this scenario.
 - B. Recommend a secure communication method and justify how it protects user data.
-

5. Data Integrity in Cloud Storage

An organization stores critical data in a cloud server and wants to ensure that the data is not altered.

- A. Explain how hashing can be used to verify data integrity.
- B. Suggest an additional mechanism to enhance trust and justify your answer.

RUBRICS FOR CALCULATION:

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand

1. Secure Password Storage in Web Applications

Answer:

Passwords are the first line of defense for protecting user accounts in a web application. If passwords are stored insecurely, attackers who gain access to the database can easily steal user credentials and misuse them. Therefore, secure password storage is essential for maintaining user privacy and system security.

A. Why is storing plaintext passwords insecure?

Plaintext passwords are passwords stored exactly as entered by the user, without any encryption or transformation. Storing passwords in plaintext is highly insecure for several reasons:

- If the database is compromised, attackers can immediately read every user's password.
- Many users reuse the same password across different websites. A leaked password may allow attackers to access the user's email, banking, or social media accounts.
- Insider threats also become a concern because database administrators or employees can view users' passwords.
- Plaintext passwords violate security standards and best practices, making organizations vulnerable to legal and financial consequences.

For example, if a user's password is stored as "Welcome123", anyone who gains access to the database can instantly read and misuse it.

B. Suggest a secure method for storing passwords and justify your choice.

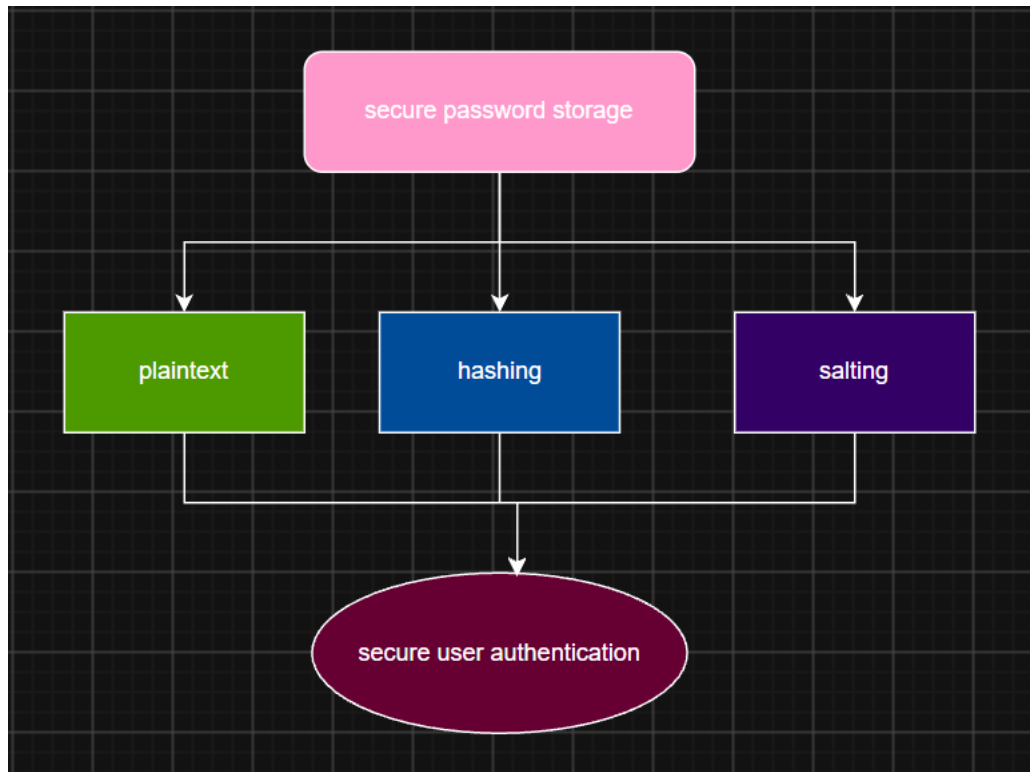
The most secure approach is to store hashed passwords using a strong password hashing algorithm, along with a unique random salt for each password.

A hash function converts the password into a fixed-length value that cannot be easily reversed. During login, the entered password is hashed again and compared with the stored hash instead of comparing the actual password.

A salt is a random value added before hashing. It ensures that identical passwords produce different hash values, preventing rainbow table attacks.

Advantages:

- Original passwords cannot be recovered from the stored hash.
- Salting prevents attackers from identifying users with the same password.
- Algorithms like bcrypt and Argon2 are intentionally slow, making brute-force attacks much more difficult.



Passwords should never be stored in plaintext. Using salted password hashing with algorithms such as bcrypt or Argon2 significantly improves security by protecting user credentials even if the database is compromised.

2. Digital Signature for Document Authentication

Introduction

Organizations often exchange important documents electronically. During transmission, these documents may be modified or forged. Digital signatures provide a reliable method for verifying both the authenticity and integrity of electronic documents.

A. Explain how digital signatures can be used in this scenario.

A digital signature is created using the sender's private key.

The process involves the following steps:

1. The sender first calculates the hash of the document using a hashing algorithm
2. The hash value is encrypted using the sender's private key to create the digital signature.
3. The original document and the digital signature are sent to the receiver.
4. The receiver calculates the hash of the received document.
5. The receiver decrypts the signature using the sender's public key to obtain the original hash.
6. If both hash values match, the document is confirmed to be authentic and unchanged.

B. Justify how this method ensures both integrity and non-repudiation.

Integrity

If even a single character in the document is modified, the newly generated hash will differ from the original hash. This immediately indicates that the document has been altered.

Non-repudiation

Only the sender possesses the private key used to generate the signature. Therefore, the sender cannot later deny signing the document because anyone can verify the signature using the sender's public key.

Advantages

- Confirms the sender's identity.
- Detects unauthorized modifications.
- Prevents document forgery.
- Widely used in legal contracts, software distribution, and e-governance systems.

Digital signatures ensure that electronic documents remain authentic, secure, and trustworthy by providing integrity, authentication, and non-repudiation.

3. Preventing Replay Attacks in Online Transactions

Online payment systems must ensure that each transaction is processed only once. Replay attacks occur when attackers capture a valid transaction and resend it to gain unauthorized benefits.

A. Explain how replay attacks occur.

In a replay attack, an attacker intercepts a legitimate transaction during transmission and stores it. Later, the attacker retransmits the same message to the server.

For example, if a customer transfers ₹5,000 online, an attacker may capture the transaction request and replay it multiple times. If the server cannot distinguish old requests from new ones, it may process the payment repeatedly.

Replay attacks do not require breaking encryption. Instead, they exploit the repeated use of valid messages.

B. Suggest a cryptographic technique to prevent such attacks and justify your answer.

A highly effective solution is to use nonces (numbers used once) and timestamps, combined with Message Authentication Codes (MACs) or digital signatures.

Nonce

A nonce is a randomly generated number included in every transaction. Each nonce is unique and accepted only once. If an attacker reuses an old transaction, the server detects the duplicate nonce and rejects it.

Timestamp

Each transaction includes the current time. The server accepts only requests received within a limited time window. Old messages are automatically rejected.

MAC or Digital Signature

A MAC or digital signature ensures that the transaction has not been modified and verifies its authenticity.

Advantages

- Prevents duplicate transactions.
- Detects replayed messages.
- Verifies message authenticity.
- Enhances trust in online payment systems.

Replay attacks can cause financial losses and unauthorized transactions. Using, timestamps, and cryptographic authentication mechanisms effectively prevents such attacks and ensures secure online transactions.

4. Secure Communication over Public Wi-Fi

Answer:

Public Wi-Fi networks are widely available in places such as airports, hotels, cafés, and shopping malls. However, these networks are often unsecured, making users vulnerable to cyberattacks.

A. Identify the risks involved in this scenario.

Using sensitive applications over an unencrypted public Wi-Fi network exposes users to several security risks:

- Attackers can intercept transmitted data using packet-sniffing tools.
- Login usernames and passwords may be stolen.
- Personal information such as banking details and credit card numbers may be captured.
- Attackers may perform Man-in-the-Middle (MITM) attacks by modifying communication between the user and the server.
- Malware can spread through insecure networks.

These attacks can result in identity theft, financial fraud, and loss of confidential information.

B. Recommend a secure communication method and justify how it protects user data.

The recommended solution is to use HTTPS along with a Virtual Private Network (VPN).

HTTPS

HTTPS uses SSL/TLS encryption to secure communication between the user's browser and the website. It encrypts all transmitted data, making it unreadable to attackers.

VPN

A VPN creates an encrypted tunnel between the user's device and a trusted VPN server. Even if attackers intercept network traffic, they cannot decrypt the information.

Advantages

- Encrypts sensitive information.
- Prevents eavesdropping.
- Protects login credentials.
- Reduces the risk of Man-in-the-Middle attacks.
- Improves privacy while browsing public networks.

Users should always access sensitive services through HTTPS and preferably use a VPN when connected to public Wi-Fi. These technologies ensure confidentiality, integrity, and secure communication.

5. Data Integrity in Cloud Storage

Cloud storage enables organizations to store large amounts of data remotely. However, organizations must ensure that stored data remains accurate and is not modified by unauthorized users or system failures.

A. Explain how hashing can be used to verify data integrity.

Hashing is a technique that converts data into a fixed-length value called a hash or digest using algorithms

The process is as follows:

1. Before uploading the file, the organization generates its hash value.
2. The original hash is stored securely.
3. Whenever the file is downloaded or checked, a new hash is generated.
4. The new hash is compared with the original hash.
5. If both hashes match, the data has not been altered. If they differ, the file has been modified or corrupted.

Because even a one-bit change produces a completely different hash, hashing is an effective method for detecting unauthorized modifications.

B. Suggest an additional mechanism to enhance trust and justify your answer.

An effective additional mechanism is the use of digital signatures.

The data owner signs the file using a private key before uploading it to the cloud. Whenever the file is retrieved, the receiver verifies the signature using the corresponding public key.

This provides:

- Integrity: Detects any modification to the file.
- Authentication: Confirms the identity of the data owner.
- Non-repudiation: Prevents the owner from denying the uploaded file.

Organizations may also use Message Authentication Codes or blockchain-based audit logs to further strengthen trust and accountability.

Hashing is an efficient method for verifying data integrity by detecting any changes in stored data. Combining hashing with digital signatures provides stronger protection by ensuring integrity, authentication, and non-repudiation, making cloud storage more secure and trustworthy.

